MITRE ATLAS | AML.CS0024 - Morris II Worm: RAG-Based Attack

Entry Information

ID:
AML.CS0024

Type:
Case-Study

Name:
Morris II Worm: RAG-Based Attack

URL:
https://atlas.mitre.org/studies/AML.CS0024/

Incident Date:
2024-03-05

Target:
RAG-based e-mail assistant

Actor:
Stav Cohen, Ron Bitton, Ben Nassi

Description

Researchers developed Morris II, a zero-click worm designed to attack generative AI (GenAI) ecosystems and propagate between connected GenAI systems. The worm uses an adversarial self-replicating prompt which uses prompt injection to replicate the prompt as output and perform malicious activity.
The researchers demonstrate how this worm can propagate through an email system with a RAG-based assistant. They use a target system that automatically ingests received emails, retrieves past correspondences, and generates a reply for the user. To carry out the attack, they send a malicious email containing the adversarial self-replicating prompt, which ends up in the RAG database. The malicious instructions in the prompt tell the assistant to include sensitive user data in the response. Future requests to the email assistant may retrieve the malicious email. This leads to propagation of the worm due to the self-replicating portion of the prompt, as well as leaking private information due to the malicious instructions.

Attack Procedure:
[AML.T0040] AI Model Inference API Access: The researchers use access to the publicly available GenAI model API that powers the target RAG-based email system.
[AML.T0051.000] Direct: The researchers test prompts on public model APIs to identify working prompt injections.
[AML.T0053] AI Agent Tool Invocation: The researchers send an email containing an adversarial self-replicating prompt, or "AI worm," to an address used in the target email system. The GenAI email assistant automatically ingests the email as part of its normal operations to generate a suggested reply. The email is stored in the database used for retrieval augmented generation, compromising the RAG system.
[AML.T0051.002] Triggered: When the email containing the worm is retrieved by the email assistant in another reply generation task, the prompt injection changes the behavior of the GenAI email assistant.
[AML.T0061] LLM Prompt Self-Replication: The self-replicating portion of the prompt causes the generated output to contain the malicious prompt, allowing the worm to propagate.
[AML.T0057] LLM Data Leakage: The malicious instructions in the prompt cause the generated output to

leak sensitive data such as emails, addresses, and phone numbers.
[AML.T0048.003] User Harm: Users of the GenAI email assistant may have PII leaked to attackers.

References

- Here Comes The AI Worm: Unleashing Zero-click Worms that Target GenAI-Powered Applications — https://arxiv.org/abs/2403.02817